

Mapeo Detallado de Métricas a Requisitos Normativos

ID	Métrica	Artículos RGPD / Marcos asociados	Comentario normativo breve
M1.1	Nº de brechas notificadas/año	RGPD arts. 33, 34; EDPB casos sobre brechas [web:14][web:28]	Mide aplicación práctica del deber de notificación y la frecuencia de materialización de riesgos.
M1.2	Nº total de incidentes con impacto en datos personales	RGPD art. 32; ENISA gestión de incidentes [web:25][web:28]	Conecta seguridad del tratamiento con ocurrencia de incidentes que afectan a datos personales.
M1.3	% de brechas mitigadas por medidas técnicas	RGPD arts. 32, 34(3); guías de cifrado AEPD/ENISA [web:21][web:25]	Refleja eficacia real de medidas como cifrado y pseudonimización para limitar comunicaciones e impacto.
M1.4	Importe total de sanciones RGPD/año (seguridad)	RGPD arts. 58–83; práctica sancionadora AEPD [web:6][web:11]	Indicador de resultado regulatorio y de gravedad percibida de incumplimientos.
M1.5	Nº de reclamaciones sobre seguridad del tratamiento	RGPD arts. 57–77; funciones de supervisión AEPD [web:6][web:11]	Aproxima el nivel de conflicto/insatisfacción en materia de seguridad y privacidad.
M2.1	% de datos en reposo cifrados	RGPD art. 32(1)(a); guías criptográficas AEPD [web:21][web:28]	Aterriza la exigencia de “medidas apropiadas” en un control técnico concreto.
M2.2	% de datos en tránsito cifrados	RGPD art. 32; ENISA recomendaciones técnicas [web:25]	Indicador de protección frente a interceptación en comunicaciones.
M2.3	% de sistemas con MFA	RGPD art. 32; NIS2 medidas técnicas [web:22][web:26][web:28]	Control reconocido para reducir riesgo de acceso no autorizado.
M2.4	Tiempo medio de parcheo de vulnerabilidades críticas	RGPD art. 32; gestión de vulnerabilidades ENISA [web:25]	Mide capacidad de mantener un nivel de seguridad adecuado frente a amenazas conocidas.
M2.5	% de tratamientos con análisis de riesgos/EIPD actualizados	RGPD arts. 24, 25, 35; enfoque basado en el riesgo [web:9][web:28]	Refleja profundidad de la responsabilidad proactiva y privacidad desde el diseño.

M2.6	Nivel de madurez ISO 27001/27701 o NIS2	RGPD art. 24; ISO 27001/27701 mapeo a RGPD [web:23] [web:27]	Utiliza marcos reconocidos como evidencia de accountability y madurez.
M3.1	MTTR-detección de incidentes	RGPD art. 32; NIS2 detección de incidentes [web:22][web:26]	Relacionado con capacidad de identificar rápidamente brechas potenciales.
M3.2	MTTR-respuesta/contención	RGPD art. 32; planes de respuesta ENISA [web:25]	Mide eficacia de la respuesta para limitar impacto sobre datos personales.
M3.3	% de brechas notificadas < 72 h	RGPD art. 33(1); EDPB digest [web:14] [web:28]	Indicador directo de cumplimiento del plazo de notificación.
M3.4	Nº de simulacros de incidentes/año	RGPD art. 32 (pruebas y evaluación periódica); ENISA [web:25]	Demuestra aplicación práctica de la obligación de probar la eficacia de medidas.
M3.5	Nº medio de acciones de mejora tras incidentes	RGPD art. 24; mejora continua y lecciones aprendidas [web:25] [web:28]	Conecta incidentes con remediación estructural.
M4.1	% de proveedores evaluados	RGPD art. 28; selección de encargados [web:28]	Mide diligencia en la elección y seguimiento de encargados del tratamiento.
M4.2	% de proveedores críticos certificados	RGPD art. 28(1); certificaciones como garantía [web:23] [web:27]	Aprovecha certificaciones reconocidas como evidencia adicional.
M4.3	Nº de incidentes originados en terceros	RGPD arts. 28, 32; cadena de suministro [web:25][web:28]	Visibiliza riesgo externo asociado a encargados y proveedores.
M4.4	% de proveedores monitorizados continuamente	RGPD art. 32; NIS2 evaluación continua [web:22][web:26]	Refuerza gestión activa del riesgo de terceros.
M5.1	Existencia/actualización de cuadro de mando	RGPD art. 24; accountability y documentación [web:28][web:27]	Mide capacidad de demostrar cumplimiento mediante indicadores agregados.

M5.2	IGM global	RGPD arts. 24, 32; marcos de madurez ISO/NIS2 [web:22] [web:27]	Índice sintético que resume múltiples obligaciones en una escala de madurez.
M5.3	Nº de reportes anuales al consejo	RGPD art. 24; gobernanza y supervisión [web:23] [web:27]	Refuerza implicación de la alta dirección en seguridad y privacidad.
M5.4	% de empleados con formación actualizada	RGPD art. 39(1)(b); factor humano [web:25][web:28]	Clave para reducir errores humanos y aumentar conciencia.
M5.5	ROI de iniciativas clave de cumplimiento	RGPD art. 32 (proporcionalidad costo-riesgo); análisis económico [web:12] [web:28]	Permite justificar que las medidas son proporcionadas pero suficientes.